

Shadow AI Discovery Workflow

Standard operating workflow for identifying, validating, triaging, and remediating unapproved or unmanaged AI use across the organization.

Prepared For	{{COMPANY_NAME}}
Version / Effective Date	v1.0 {{EFFECTIVE_DATE}}

Purpose This workflow helps the organization find AI use that escaped formal governance, determine what data and risk are involved, decide whether the activity can be allowed, restricted, replaced, or stopped, and document the result in a repeatable way.

Use this as a controlled workflow document and pair it with a live findings log or case tracker. Update it whenever discovery methods, review criteria, or escalation paths materially change.

1. Workflow Overview

Shadow AI is the use of AI tools, models, plugins, automations, or vendor features outside the organization's approved governance process. The issue is not that people are experimenting. The issue is that the business cannot manage what it cannot see.

What it covers	Why it matters	Minimum owner	Typical triggers
Unapproved AI tools, unmanaged AI features inside existing vendors, risky employee usage patterns, and workarounds that bypass standard review.	Reduces data leakage, weak contracting, unreviewed automation, and surprise customer or employee impact.	AI Governance Lead with Security and IT support.	Browser extensions, public AI chat tools, SaaS add-ons, expense claims, user tips, vendor rollouts, or incident leads.

Common examples of shadow AI

- Employees entering confidential text into consumer AI tools that were never approved for business use.
- A vendor quietly enabling generative AI features that process company or customer data under new terms.
- Browser plugins or meeting assistants that record, summarize, or route internal content without security review.
- Teams using AI automations connected to email, CRM, HR, finance, or source code systems outside approved controls.

2. Discovery Sources and Roles

A good discovery program does not rely on one magic source. It uses several lightweight signals that, together, reveal where AI use has drifted outside policy.

Recommended discovery sources

Signal source	What to review	What it can reveal
Browser / endpoint signals	Extensions, downloads, bookmarks, desktop apps, or repeated access to public AI tools.	Unmanaged AI applications and plugins.
SaaS and SSO inventory	Connected apps, OAuth grants, new feature enablement, shadow sign-ups.	Vendor AI features and unreviewed app usage.
Expense and procurement data	AI subscriptions, trials, or team-paid tools.	Paid AI tooling outside formal approval.

Employee reporting	Manager tips, user questions, and self-disclosures.	Workarounds and real-world use patterns.
Incident and audit findings	Privacy, security, legal, or compliance observations.	Higher-risk cases needing escalation.

Roles and responsibilities

Role	Key responsibilities
AI Governance Lead	Owns workflow, coordinates review, maintains findings log, and drives closure.
Security	Reviews data exposure, technical risks, access, logging, and containment needs.
IT / Platform Owner	Validates approved alternatives, tenant controls, and support options.
Privacy / Legal / Compliance	Reviews data handling, contract terms, privacy impact, and legal triggers when needed.
Business Manager / Use Owner	Explains the business purpose, confirms users and data, and owns remediation actions.

3. Standard Workflow Steps

The workflow below is designed to be fast enough for SMB use and serious enough to stand up to audit or leadership scrutiny.

Step	Workflow stage	Core action	Primary output
1	Identify signal	Capture the source of concern, such as a browser signal, vendor feature, expense, manager report, or incident note.	Initial finding opened
2	Validate the tool or feature	Confirm the exact tool, model, plugin, or AI-enabled feature in use. Do not investigate ghosts.	Tool confirmed
3	Assess business context	Identify the team, owner, purpose, users, integrations, and business dependency.	Use context documented
4	Assess data exposure	Determine what data is entered, generated, stored,	Data exposure summary

		shared, or used for model training.	
5	Triage risk	Assign an initial risk rating using data sensitivity, user impact, automation level, and vendor concerns.	Risk rating assigned
6	Decide disposition	Allow, allow with conditions, replace, restrict, block, or escalate. Document why.	Disposition decision
7	Remediate and communicate	Issue instructions to users, managers, IT, procurement, or security. Capture deadlines.	Remediation plan
8	Track to closure	Verify action completion, update the log, and record the final status in the AI use case registry where applicable.	Closed finding / linked record

Operating rule:

A shadow AI finding is not complete when the team says “we stopped using it.” It is complete when the organization has evidence of the decision, the remediation, and the closure.

4. Risk and Disposition Guidance

Not every finding deserves the same reaction. Some cases can be brought under governance quickly. Some need to be shut down before they become tomorrow’s apology email.

Risk	Typical indicators	Recommended disposition	Example response
Low	Non-sensitive drafting or summarization with no system integration and no customer impact.	Allow with registration	Move to approved tool or log the use case and remind the team of policy conditions.
Medium	Internal confidential data, recurring team use, or unmanaged vendor AI features inside existing systems.	Allow with conditions or replace	Require approved tenant, disable training on customer data, set usage guardrails, and document owner.
High	Sensitive data, customer content, HR / finance	Escalate and restrict	Pause expansion, involve security and privacy, and

	impact, automation, or unclear vendor terms.		define controls before use can continue.
Critical	Regulated data, major decision impact, legal or contractual conflict, or active unsafe behavior.	Block or stop immediately	Contain access, preserve evidence, notify stakeholders, and route for executive decision if needed.

5. Discovery Investigation Checklist

Use the questions below for each finding. The goal is not paperwork for its own sake. The goal is to avoid guessing.

#	Question	Response / field	Notes or evidence
1	What tool, model, plugin, or AI feature was identified?	{{Enter response}}	{{Evidence / notes}}
2	Which team or individuals are using it?	{{Enter response}}	{{Evidence / notes}}
3	What business purpose does it serve?	{{Enter response}}	{{Evidence / notes}}
4	What data is entered, uploaded, recorded, or generated?	{{Enter response}}	{{Evidence / notes}}
5	Is any confidential, personal, regulated, or customer data involved?	{{Enter response}}	{{Evidence / notes}}
6	Does the tool integrate with email, files, CRM, HR, finance, code, or other systems?	{{Enter response}}	{{Evidence / notes}}
7	Does the vendor retain data or train models on submitted content?	{{Enter response}}	{{Evidence / notes}}
8	Is there an approved alternative already available?	{{Enter response}}	{{Evidence / notes}}
9	What immediate action is required: allow, restrict, replace, block, or escalate?	{{Enter response}}	{{Evidence / notes}}

10	Who owns remediation and by when?	{{Enter response}}	{{Evidence / notes}}
----	-----------------------------------	--------------------	----------------------

6. Shadow AI Findings Log Template

Use this log as the minimum operating record for open findings. If your team manages findings in a ticketing system, keep the same fields.

Finding ID	Tool / Feature	Signal Source	Team / Owner	Data Exposure	Risk	Disposition	Due Date	Status
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}
{{SAI-00X}}	{{Tool name}}	{{Source}}	{{Owner}}	{{Data type(s)}}	{{L/M/H}}	{{Decision}}	{{Date}}	{{Open/Closed}}

Minimum standard: Every finding should link to a named owner, a disposition, and a due date. A log without ownership is just a museum of avoided decisions.

7. Example Findings and Actions

These examples show how the workflow can be used in real SMB situations without drowning the team in process.

Finding	Source	Risk	Disposition	Reason / action
Public AI chatbot used to draft internal marketing copy	Manager report	Low	Allow with registration	Move team to approved enterprise tool and record the use case.
Meeting assistant records customer calls under free trial terms	SaaS review	High	Restrict and escalate	Pause use until retention, consent, and contract terms are reviewed.
Browser plugin summarizes HR emails	Endpoint signal	Critical	Block immediately	Sensitive employee data and unmanaged extension risk require containment and removal.
CRM vendor turned on gen-AI drafting feature by default	Vendor notice	Medium	Allow with conditions	Confirm data-use settings, logging, and user guidance before rollout.

8. Approval and Control Record

Use this section to document approval of the workflow itself and the individual accountable for operating it.

Approved By	{{NAME / TITLE}}
Document Owner	{{NAME / TITLE}}
Effective Date	{{DATE}}
Review Cycle	At least annually or upon material change
Related Records	AI Use Case Registry; AI Acceptable Use Policy; Vendor Risk Review